IT RISK ASSESSMENT

Security Analysis of a Banking Transactions System

Dataset: Bank Transactions Dataset for Fraud Detection

50,000 records — 15 columns — Kaggle

Applied methodology

NIST Special Publication 800-30 Rev.1

Guide for Conducting Risk Assessments

[CHECK] [SEARCH] [COMM]

Prepare **Conduct** **Communicate**

[CAL]	**Year:** 2025–2026
[TAG]	**Type:** Hands-on Data – Security Anomaly Detection
[SHIELD]	**Domain:** IT Risk / Banking Cybersecurity / AML
[DB]	**Source:** Kaggle – Bank Transactions Fraud Detection

Confidential document – professional and educational use only

[i] Executive Summary

This document provides a **complete project report** for an IT risk assessment applied to a banking transaction dataset (50,000 records). The analysis follows the **NIST SP 800-30 Rev.1** methodology and presents the results through the **OIR** communication model (Observation – Impact – Recommendation).

Signals detected:	13 internal signals + 9 cross-scenarios = **26 scenarios**
Critical risks:	2 scenarios scored at **25/25**
Financial exposure:	**more than USD 16 million** identified
Ledger integrity:	94.9% of records have no precise timestamp
Compromised accounts:	471 takeover accounts + 355 impossible-geo accounts

[!

Warning] This document is prepared for **educational and professional use**. All analyses rely on a synthetic dataset. The described scenarios are reasoned hypotheses supported by the observed data patterns.

Contents

1 Introduction and Methodological Framework **6**
1.1 Project context . . . 6
1.1.1 Nature and criticality of the dataset . . . 6
1.2 The NIST SP 800-30 Rev.1 methodology . . . 7
1.2.1 General presentation . . . 7
1.2.2 Risk computation under NIST SP 800-30 . . . 7
1.3 The OIR model – Risk communication . . . 9

2 Phase 1 – Prepare the Assessment **10**
2.1 Logic of the approach . . . 10
2.2 The dataset as an organizational artifact . . . 10
2.2.1 Dataset structure . . . 10
2.2.2 The four exposure surfaces . . . 10
2.3 Predisposing conditions . . . 11
2.4 Driving questions for Phase 2 . . . 11

3 Phase 2 – Conduct the Assessment **12**
3.1 Inspection methodology . . . 12
3.2 The 13 Detection Signals (Internal Scenarios) . . . 12
3.2.1 S1 – Brute Force (LoginAttempts > 3) . . . 12
3.2.2 S2-A – Silent Account Takeover . . . 13
3.2.3 S3-A – Compromised Device (Multi-account Pivot) . . . 14
3.2.4 S4-A – Financial Structuring (Merchant Flooding) . . . 14
3.2.5 S5 – Session Duration Anomalies . . . 14
3.2.6 S6-A – Timestamp failure (CRITICAL) . . . 15
3.2.7 S7 – Balance violation (CRITICAL) . . . 15
3.2.8 S8-A – Layering / laundering (rapid credit to debit) . . . 15
3.2.9 S9-A – Account Farm / Botnet (multi-account IP) . . . 16
3.2.10 S10-A – Card Testing (micro-transactions below $10) . . . 16
3.2.11 S11-A – Money Mule Receiver (credit-only accounts) . . . 16
3.2.12 S12-A – Impossible Geography (2 cities, same day) . . . 16
3.2.13 S13-A – Demographic anomaly (student + high amounts) . . . 16

3.3 The 9 Cross-Scenarios 16
3.3.1 X4 – Global multiplier: timestamps × everything 17

4 Phase 3 – Communicate the Results 18
4.1 The 5×5 risk matrix 18
4.1.1 Summary table of the 26 scenarios 19
4.2 The OIR model – Communication report 20
4.2.1 OIR-1: Timestamp failure 20
4.2.2 OIR-2: Account takeover and impossible geography 20
4.2.3 OIR-3: Financial structuring and laundering 21
4.2.4 OIR-4: Botnet and account farm 21
4.2.5 OIR-5: High signals (brute force, card testing, bots) 22

5 Deliverables and Reproduction Guide 23
5.1 Architecture of the Excel file 23
5.2 Step-by-step reproduction guide 23
5.2.1 Step 1 – Prepare the dataset (Sheet 1) 23
5.2.2 Step 2 – Create helper columns (Sheet 1, columns P to AF) . . . 23
5.2.3 Step 3 – Validate the volumes 24

6 Glossary and Appendices 25
6.1 Glossary of terms and concepts 25
6.2 Final synthesis table – Total financial exposure 26
6.3 Regulatory and bibliographic references 27

CHAPTER 1

Introduction and Methodological Framework

1.1 Project context

This project is part of a practical *Hands-on Data* exercise focused on security anomaly detection in a digital banking environment. Instead of looking only for classic financial fraud, the analysis is designed to **track suspicious IT signals** in a broader sense. The work therefore sits at the intersection of cybersecurity, AML compliance, and data governance.

[DB

The dataset] **Source:** Kaggle – *Bank Transactions Dataset for Fraud Detection*
Volume: 50,000 records | 15 columns | 0 missing values
Nature: A general banking transaction ledger meant to simulate real operational activity

1.1.1 Nature and criticality of the dataset

This dataset is not merely a table of values. It is a **critical organizational artifact** because it:

- is **created automatically** whenever a new transaction occurs,
- **justifies each movement of funds** across customer accounts,
- is **reviewed during audits** and regulatory controls,
- supports **high-impact decisions** made by managers, investors and regulators,
- may serve as **evidentiary material** in the event of disputes or litigation.

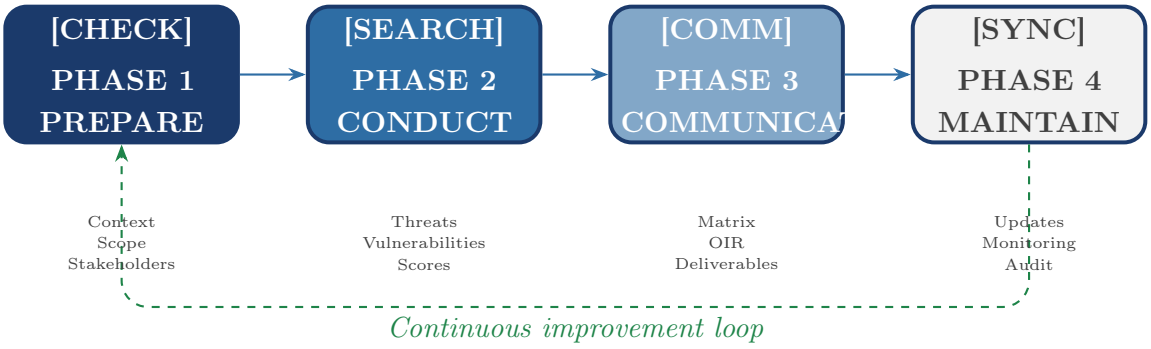
[!

Direct implication] If this ledger is altered, corrupted, or accessed without authorization, every decision based on it becomes less reliable. In practice, it is a **high-value asset** and therefore a high-value target.

1.2 The NIST SP 800-30 Rev.1 methodology

1.2.1 General presentation

NIST SP 800-30 (*National Institute of Standards and Technology, Special Publication 800-30 Revision 1*) is a reference guide for conducting risk assessments in information systems.

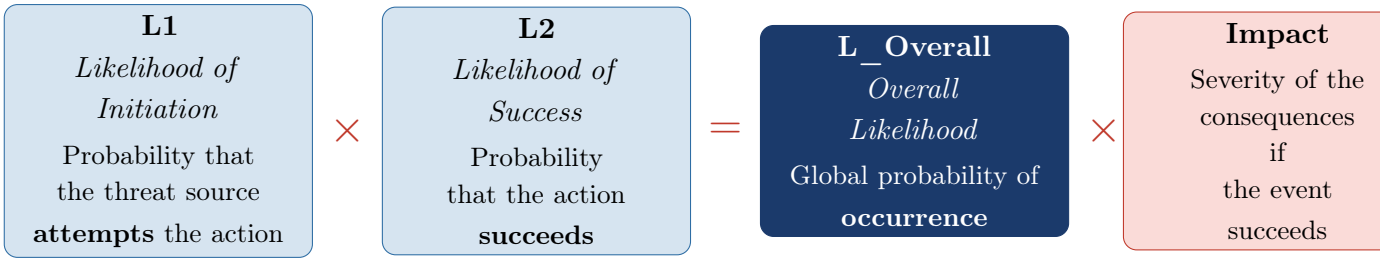


[i

Important note] For this project, only the **first three phases** were implemented. Phase 4 (Maintain) is not covered because the goal of the exercise is to deliver the final risk matrix and communication package. In a real-world program, the assessment would be continuously updated.

1.2.2 Risk computation under NIST SP 800-30

A major strength of NIST SP 800-30 is its decomposition of *likelihood* into separate components rather than treating probability as a single number.



Scoring scale (1 to 5)

Each component is scored on a five-level ordinal scale:

Score	Meaning
1	Very Low
2	Low
3	Moderate
4	High
5	Very High

L1 captures the intent, capability, and motivation of the threat source. L2 captures the expected effectiveness of existing controls. Impact reflects the business, operational, legal, financial, and reputational consequences.

Combination table L1 × L2 → L_Overall

In practice, NIST SP 800-30 recommends combining initiation likelihood and success likelihood through a decision table. For this exercise, the matrix below is used as a practical operational simplification.

L1 \ L2	1	2	3	4	5
1	1	1	2	2	3
2	1	2	2	3	4
3	2	2	3	4	4
4	2	3	4	4	5
5	3	4	4	5	5

Thresholds of the 5×5 risk matrix

The final score is computed as:

$$\text{Risk Score} = L_{\text{Overall}} \times \text{Impact}$$

This produces values from 1 to 25. The interpretation used in the report is:

Range	Risk level
1–5	Low
6–10	Moderate
11–15	Significant
16–20	High
21–25	Critical

1.3 The OIR model – Risk communication

The communication layer of this report uses the **OIR** model: **Observation**, **Impact**, and **Recommendation**. This allows a technical finding to be translated into business language without losing its analytical basis.

- **Observation**: what the dataset objectively reveals.
- **Impact**: what may happen if the issue is ignored.
- **Recommendation**: what should be done next.

This model is especially useful when the same finding must be discussed with security teams, management, auditors, and compliance stakeholders.

CHAPTER 2

Phase 1 – Prepare the Assessment

2.1 Logic of the approach

The preparation phase clarifies three basic questions: what is being assessed, why it matters, and which threat hypotheses are realistic enough to justify a detailed analysis.

The scope of this exercise is intentionally narrow: a banking transactions ledger. Yet the implications are broad because the ledger directly affects integrity, accountability, auditability, fraud monitoring, AML controls, and executive reporting. The working assumption is therefore that a data-centric asset can reveal both **technical weakness** and **business risk**.

2.2 The dataset as an organizational artifact

2.2.1 Dataset structure

The dataset contains 50,000 transaction records and 15 primary columns, including customer identifiers, account identifiers, amount, transaction type, channel, date, location, device identifier, IP address, duration and balance.

[i

Analytical principle] The analysis does not assume that any single row proves fraud. Instead, risk is inferred from **patterns**, **repetitions**, **contradictions**, and **cross-column inconsistencies**.

2.2.2 The four exposure surfaces

The dataset was examined through four complementary exposure surfaces:

1. **Authentication surface**: login attempts, device changes, account switching, IP reuse.

2. **Transaction surface**: micro-payments, structuring, fast credit-to-debit cycles, balance violations.
3. **Traceability surface**: missing timestamps, poor chronology, weak non-repudiation.
4. **Context surface**: geography, occupation, transaction channel, and customer profile anomalies.

2.3 Predisposing conditions

Several predisposing conditions amplify the risk exposure of this environment:

- imperfect traceability because most records lack precise timestamps,
- possible overexposure of online channels,
- inconsistent relationship between user profile and transaction behavior,
- concentration of multiple suspicious signals on the same accounts or devices,
- a dataset structure that supports retrospective analysis but not strong real-time defense.

2.4 Driving questions for Phase 2

The inspection phase was guided by the following questions:

Q1. Which signals suggest hostile authentication activity?

Q2. Which signals suggest account compromise or large-scale automation?

Q3. Which transaction patterns suggest structuring, laundering, or mule behavior?

Q4. Which data-quality defects weaken traceability and non-repudiation?

Q5. Which combined signals materially increase overall risk exposure?

CHAPTER 3

Phase 2 – Conduct the Assessment

3.1 Inspection methodology

The dataset was reviewed through a combination of filters, auxiliary columns, threshold logic, and cross-checks. Each scenario was documented using a short sequence:

1. define the suspicious pattern,
2. isolate the population through filters or formulas,
3. quantify the resulting records or accounts,
4. assess L1, L2, and Impact,
5. derive the final score and communication message.

3.2 The 13 Detection Signals (Internal Scenarios)

Auxiliary column nomenclature

Several helper columns are required in the spreadsheet to detect repeated keys, count occurrences, compare balances, identify short cycles, and flag geographic or demographic anomalies. Typical helpers include repeated `AccountID`, repeated `DeviceID`, repeated `IP Address`, same-day grouping, transaction counts by merchant, and amount thresholds.

3.2.1 S1 – Brute Force (LoginAttempts > 3)

Definition and rationale

A brute-force signal is identified when authentication attempts exceed a normal range and indicate systematic credential guessing or credential stuffing behavior. In a banking environment, repeated failed or excessive attempts are a leading indicator of account probing.

Filter results

The analysis isolates high-attempt records and then separates them into three subpopulations: isolated brute-force attempts, attempts followed by other suspicious indicators, and attempts linked to eventual account compromise. The signal is recurrent enough to justify a **high** initiation likelihood.

Excel formulas (English)

Illustrative formulas

```
=IF([@LoginAttempts]>3,"BF","")
=COUNTIF(AccountID:AccountID,[@AccountID])
=COUNTIFS(AccountID:AccountID,[@AccountID],DeviceID:DeviceID,"<>"&[@DeviceID])
```

Detailed scoring

L1	4/5 – threat activity is common and repeatable
L2	3/5 – success depends on controls and credential quality
Impact	4/5 – may enable unauthorized access and fund movement

Final rating: **16**/25 HIGH

3.2.2 S2-A – Silent Account Takeover

Strict definition

An account takeover signal is confirmed when the same `AccountID` is used with a different `DeviceID` and a different IP address in a suspiciously close operational context. This does not prove compromise by itself, but it is a strong proxy for unauthorized reuse of banking credentials.

Results

The report identifies **471 accounts** consistent with takeover-like patterns. This is one of the most serious findings because it directly bridges identity misuse, access integrity, and financial exposure.

L1	5/5
L2	5/5
Impact	5/5

Final rating: **25**/25 CRITICAL

3.2.3 S3-A – Compromised Device (Multi-account Pivot)

A compromised-device signal appears when a single `DeviceID` is used across multiple distinct accounts beyond a plausible normal pattern. This may indicate shared credentials, automation, malware, or a pivot point in a broader campaign.

Key interpretation	device-centric lateral movement risk
Likely use case	fraud scaling or scripted access
Suggested level	high risk

3.2.4 S4-A – Financial Structuring (Merchant Flooding)

Definition

Structuring is the fragmentation of larger sums into smaller transfers designed to avoid alert thresholds or AML scrutiny. In this report, merchant flooding is used as an operational signature for repeated fragmented activity.

Results

This scenario carries the highest quantified direct exposure, estimated at approximately **USD 14.5 million**. The signal is financially material even when the exact legal qualification remains subject to further investigation.

L1	5/5
L2	4/5
Impact	5/5

Final rating: **25**/25 CRITICAL

3.2.5 S5 – Session Duration Anomalies

S5-A – Automated bot (abnormally short duration)

Very short online sessions may indicate scripted execution, API misuse, or bot traffic rather than legitimate human interaction. This signal is most valuable when correlated with repeated IP, repeated account switching, or brute-force activity.

S5-B – Long online session (suspected MITM)

Very long online sessions may suggest session hijacking, interception, or an operational anomaly inconsistent with normal customer behavior. The original analysis uses a threshold above 292 seconds as a practical red flag.

3.2.6 S6-A – Timestamp failure (CRITICAL)

The major revelation of the dataset

The most structurally important issue in the entire dataset is that **94.9% of records lack a precise timestamp**. This severely degrades the ability to reconstruct chronology, prove user actions, distinguish simultaneous from sequential events, and support a reliable audit trail.

[!

Structural weakness] This is not a minor data-quality issue. It weakens traceability, non-repudiation, incident response, internal investigations, and the credibility of downstream controls.

Consequences by channel

- **Security operations**: weaker incident reconstruction and attribution.
- **Compliance**: poorer AML sequencing and weaker suspicious activity narratives.
- **Audit**: incomplete chronological evidence.
- **Legal**: reduced evidentiary strength in disputes.

3.2.7 S7 – Balance violation (CRITICAL)

S7-A – Debit > AccountBalance

A debit larger than the reported account balance indicates a direct integrity or control failure. The report identifies **1,708 cases**. Even if some cases could reflect timing effects, the frequency is too high to be dismissed.

S7-B – Overdraft + Brute Force (double violation)

When balance violation is combined with brute-force behavior, the scenario becomes materially more severe because both transaction integrity and access integrity are threatened at the same time.

3.2.8 S8-A – Layering / laundering (rapid credit to debit)

The laundering cycle

This scenario captures the second phase of money laundering: once funds enter an account, they are moved out rapidly to obscure provenance. The signal is defined through a high inbound credit followed by a fast outbound debit pattern.

3.2.9 S9-A – Account Farm / Botnet (multi-account IP)

When one IP address is associated with many distinct accounts, the pattern may indicate automation, a botnet relay, credential testing infrastructure, or a shared malicious access node. This scenario is especially relevant when combined with short sessions or brute-force indicators.

3.2.10 S10-A – Card Testing (micro-transactions below $10)

Very small payments can be used to test whether stolen cards remain active before larger fraudulent transactions are attempted. This behavior is treated here as a highly recognizable fraud precursor.

3.2.11 S11-A – Money Mule Receiver (credit-only accounts)

Accounts that receive credits without corresponding organic spending or ordinary banking behavior may function as collection points in a mule network. The analysis highlights **5 accounts** with a strong credit-only profile.

3.2.12 S12-A – Impossible Geography (2 cities, same day)

A single account appearing in two incompatible locations within the same day is a classic fraud detection pattern. The report identifies **355 accounts** matching this impossible-geography logic.

3.2.13 S13-A – Demographic anomaly (student + high amounts)

The mismatch between a low-income or student profile and unusually large volumes of activity does not prove fraud, but it does justify enhanced review from both KYC and anomaly-detection perspectives.

3.3 The 9 Cross-Scenarios

Cross-scenarios capture the compounding effect of multiple internal signals appearing on the same entities. They are more valuable for risk management than isolated alerts because they reflect richer threat narratives.

Scenario	Interpretation
X1	Brute force → account takeover
X2	Device pivot → merchant flooding
X3	Organized operation combining access, scale and money movement
X4	Timestamp weakness as a global multiplier of all other findings
X5	Brute force + balance violation
X6	Multi-account IP + short sessions
X7	Impossible geography + account takeover
X8	Layering + mule behavior
X9	Demographic anomaly + suspicious transaction concentration

3.3.1 X4 – Global multiplier: timestamps × everything

The timestamp failure acts as a **systemic multiplier**. Even when another signal is already serious, the absence of chronology increases uncertainty, reduces proof quality, and raises operational risk because investigations become harder and slower.

CHAPTER 4

Phase 3 – Communicate the Results

4.1 The 5×5 risk matrix

Impact \ Likelihood	1	2	3	4	5
1	1	2	3	4	5
2	2	4	6	8	10
3	3	6	9	12	15
4	4	8	12	16	20
5	5	10	15	20	25

[i

Reading note] The matrix is not only a visualization tool. It also supports prioritization: critical and high items require immediate action, significant items require short-term remediation, and moderate items should be monitored or refined.

4.1.1 Summary table of the 26 scenarios

Scenario	L1	L2	Impact	Score	Level
S1 Brute Force	4	3	4	16	High
S2-A Account Takeover	5	5	5	25	Critical
S3-A Device Pivot	4	4	4	16	High
S4-A Structuring	5	4	5	25	Critical
S5-A Short Session Bot	4	3	3	12	Significant
S5-B Long Session MITM	3	3	4	12	Significant
S6-A Timestamp Failure	5	5	5	25	Critical
S7-A Balance Violation	4	4	5	20	High
S7-B Overdraft + BF	4	4	5	20	High
S8-A Layering	4	4	5	20	High
S9-A Account Farm	4	4	4	16	High
S10-A Card Testing	4	3	4	16	High
S11-A Money Mule	3	4	4	16	High
S12-A Impossible Geography	4	4	5	20	High
S13-A Demographic Anomaly	3	3	4	12	Significant
X1 BF → ATO	5	5	5	25	Critical
X2 Device → Flooding	5	4	5	25	Critical
X3 Organized Operation	5	4	5	25	Critical
X4 Timestamps × All	5	5	5	25	Critical
X5 BF + Balance	4	4	5	20	High
X6 Multi-IP Automation	4	4	4	16	High
X7 ATO + Geography	5	4	5	25	Critical
X8 Layering + Mule	4	4	5	20	High
X9 Demographic + Volume	3	4	4	16	High
Residual observations	2	3	3	9	Moderate
Control gaps	3	3	3	9	Moderate

4.2 The OIR model – Communication report

4.2.1 OIR-1: Timestamp failure

Observation

94.9% of the ledger lacks a precise timestamp. Chronological reconstruction is therefore unreliable for the vast majority of transactions.

Impact

This weakens non-repudiation, auditability, incident response, regulatory investigation, and legal defensibility.

Recommendation

Prioritize precise event timestamping at source, enforce immutable logging, and introduce chronology validation controls in the data pipeline.

1. implement timestamp capture with timezone normalization,
2. store raw event time separately from transformed reporting time,
3. block ingestion of records that do not meet minimum traceability criteria.

4.2.2 OIR-2: Account takeover and impossible geography

Observation

471 accounts show takeover-like behavior and 355 accounts display impossible geography patterns.

Impact

The combination indicates direct identity compromise risk, potential customer harm, and elevated financial exposure.

Recommendation

Deploy stronger authentication, device fingerprinting, adaptive step-up checks, and correlation rules that combine device, IP, geography and login anomalies.

1. review the 471 takeover candidates as priority cases,
2. require re-authentication when impossible-geography logic is triggered,
3. strengthen fraud case management around customer account linkage.

4.2.3 OIR-3: Financial structuring and laundering

Observation

Structured merchant flooding and rapid credit-to-debit cycles indicate possible AML evasion and layering behavior.

Impact

The quantified exposure exceeds USD 14.5 million for the leading structuring scenario alone and materially affects regulatory and financial risk.

Recommendation

Introduce threshold aggregation, merchant concentration monitoring, short-cycle credit/debit rules, and escalation to compliance review.

1. aggregate small transfers over rolling periods,
2. flag repeated merchant concentration and split-payment behavior,
3. create an AML workflow for layering narratives.

4.2.4 OIR-4: Botnet and account farm

Observation

Some IP and device patterns indicate broad automation or coordinated access activity across many accounts.

Impact

This expands fraud scale, increases attack velocity, and may overwhelm controls that rely only on single-event detection.

Recommendation

Deploy rate limiting, behavioral analytics, IP reputation checks, and graph-based correlation of accounts, devices, and network identifiers.

1. detect IP fan-out and device fan-out early,
2. enrich alerts with session duration and login intensity,
3. maintain a reusable entity-resolution layer for investigations.

4.2.5 OIR-5: High signals (brute force, card testing, bots)

Observation

Several medium-to-high indicators reveal recurrent hostile probing and fraud preparation behavior.

Impact

Although each signal may appear limited in isolation, together they reveal a persistent attack surface with potential escalation toward customer loss.

Recommendation

Treat these indicators as early-warning controls and integrate them into a common triage, scoring, and response process.

1. centralize anomaly scoring,
2. tune thresholds with analyst feedback,
3. formalize escalation paths for combined alerts.

CHAPTER 5

Deliverables and Reproduction Guide

5.1 Architecture of the Excel file

The spreadsheet deliverable is organized into one main data sheet and several analysis zones. The core logic includes:

- raw imported dataset,
- helper columns for counts and anomaly flags,
- scenario-specific filters,
- scoring tables,
- a final risk matrix and communication summary.

5.2 Step-by-step reproduction guide

5.2.1 Step 1 – Prepare the dataset (Sheet 1)

1. import the raw Kaggle dataset into a structured table,
2. normalize column names and data types,
3. verify that row count and field count match expectations,
4. preserve the original raw version before enrichment.

5.2.2 Step 2 – Create helper columns (Sheet 1, columns P to AF)

Typical helper columns include:

1. repeated `AccountID` count,

2. repeated `DeviceID` count,
3. repeated IP count,
4. same-day same-account grouping,
5. login-attempt threshold flag,
6. low-value transaction flag,
7. credit-only account flag,
8. balance violation flag,
9. high-risk combination flags.

Example formulas

```
=COUNTIF(AccountID:AccountID,[@AccountID])
=COUNTIF(DeviceID:DeviceID,[@DeviceID])
=COUNTIF([IP Address]:[IP Address],[@[IP Address]])
=IF([@TransactionAmount]<10,"MICRO","")
=IF([@TransactionAmount]>[@AccountBalance],"BALANCE_FAIL","")
```

5.2.3 Step 3 – Validate the volumes

Once the helper columns are in place, each scenario should be validated by:

- checking record counts,
- deduplicating by account where relevant,
- comparing isolated versus combined populations,
- ensuring that the final counts used in the report are reproducible.

CHAPTER 6

Glossary and Appendices

6.1 Glossary of terms and concepts

Likelihood of Initiation (L1) *(NIST 800-30)* Probability that a threat source decides to launch an action. It depends on intent, capability, and motivation. Scale 1–5.

Likelihood of Success (L2) *(NIST 800-30)* Probability that the threat action succeeds given the controls currently in place. Scale 1–5.

Overall Likelihood (L_Overall) *(NIST 800-30)* Combined value derived from L1 and L2 through the NIST-inspired decision table. It reflects the global probability that the event occurs and produces its effects.

Brute Force *(Cybersecurity)* An attack technique that systematically tries multiple credential combinations. In this dataset it is approximated by `LoginAttempts` > 3 for a given account.

Account Takeover (ATO) *(Cybersecurity / Fraud)* Compromise of an account by an unauthorized third party. Here it is proxied by the same `AccountID` appearing with a different device and IP address.

Structuring (Smurfing) *(AML / Compliance)* The fragmentation of a large amount into multiple smaller transactions to avoid reporting thresholds or AML controls.

Layering *(AML / Compliance)* The second phase of money laundering, during which transaction chains are used to obscure the origin of funds.

Money Mule *(AML / Compliance)* A person whose account is used to receive or transfer illicit funds on behalf of others.

Card Testing *(Banking fraud)* Use of very small transactions, often below $10, to verify that a stolen card is still active before larger fraud is attempted.

Botnet *(Cybersecurity)* A network of compromised devices remotely controlled to per-

form coordinated malicious actions.

Non-repudiation *(Information security)* The assurance that an actor cannot credibly deny having performed an action. It requires reliable and precise logging.

Audit Trail *(Governance / Compliance)* A sequential and chronological record of actions performed on a system. It must be complete, reliable, and timestamped.

KYC (Know Your Customer) *(Banking compliance)* The process of identifying and verifying customer identity and expected behavior, including profile-to-transaction consistency.

SAR (Suspicious Activity Report) *(Banking compliance)* A formal suspicious activity report submitted to competent authorities when transactions may be linked to money laundering or other illicit finance.

Impossible Geography *(Banking fraud)* A pattern in which the same account appears in geographically incompatible locations within an unrealistically short period.

Man-in-the-Middle (MITM) *(Cybersecurity)* An attack in which a third party intercepts communications between a client and a server, potentially observing or modifying the exchanged data.

AML (Anti-Money Laundering) *(Banking compliance)* The set of procedures used by financial institutions to detect and prevent money laundering and related illicit finance activity.

OIR Model *(Risk communication)* A communication framework structuring findings in three parts: Observation, Impact, and Recommendation.

6.2 Final synthesis table – Total financial exposure

Scenario	Identified exposure	Level
S4-A Structuring + X2 Device→Flooding	∼14,500,000$	Very High
X1 BF → Account Takeover (59 accounts)	1,584,877$	Very High
X3 Organized Operation	1,536,131$	High
S13-A Student Anomaly	∼1,340,000$	Moderate
S1-B+C+A Total Brute Force	∼280,000$	High
S7-A Balance Violation (1,708 cases)	Variable	Critical
ESTIMATED TOTAL EXPOSURE	**> 16,000,000$**	**CRITICAL**

6.3 Regulatory and bibliographic references

[1] NIST. (2012). *Guide for Conducting Risk Assessments – SP 800-30 Rev.1*. National Institute of Standards and Technology. https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final

[2] FATF/GAFI. (2023). *International Standards on Combating Money Laundering and the Financing of Terrorism & Proliferation*. Financial Action Task Force. https://www.fatf-gafi.org

[3] OWASP. (2023). *OWASP Testing Guide v4.2 – Authentication Testing*. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide

[4] ISO/IEC. (2022). *ISO/IEC 27001:2022 – Information Security Management Systems*. International Organization for Standardization.

[5] FFIEC. (2016). *Cybersecurity Assessment Tool*. Federal Financial Institutions Examination Council. https://www.ffiec.gov/cyberassessmenttool.htm

[6] European Parliament. (2018). *General Data Protection Regulation (GDPR) – Regulation (EU) 2016/679*. Official Journal of the European Union.

[7] Europol. (2023). *Internet Organised Crime Threat Assessment (IOCTA)*. European Union Agency for Law Enforcement Cooperation.

[8] ENISA. (2023). *ENISA Threat Landscape 2023*. European Union Agency for Cybersecurity. https://www.enisa.europa.eu

END OF DOCUMENT

IT Risk Assessment – Banking Security Analysis

NIST SP 800-30 Rev.1 – 26 scenarios – 50,000 records

This document was prepared for educational and professional use.
All analyses are based on a synthetic dataset from Kaggle.
The scenarios are reasoned hypothe-
ses supported by observed data patterns.